Effect of the grounding mechanism

5 scenarios × 3 modes × 3 runs · temperature 0 · gpt-5.4

Mode	Citation	Recall	F1
grounded	**1.00 (sd 0.00)**	**0.95**	**0.27**
rag	0.95	0.70	0.32
ungrounded	0.74	0.68	0.27

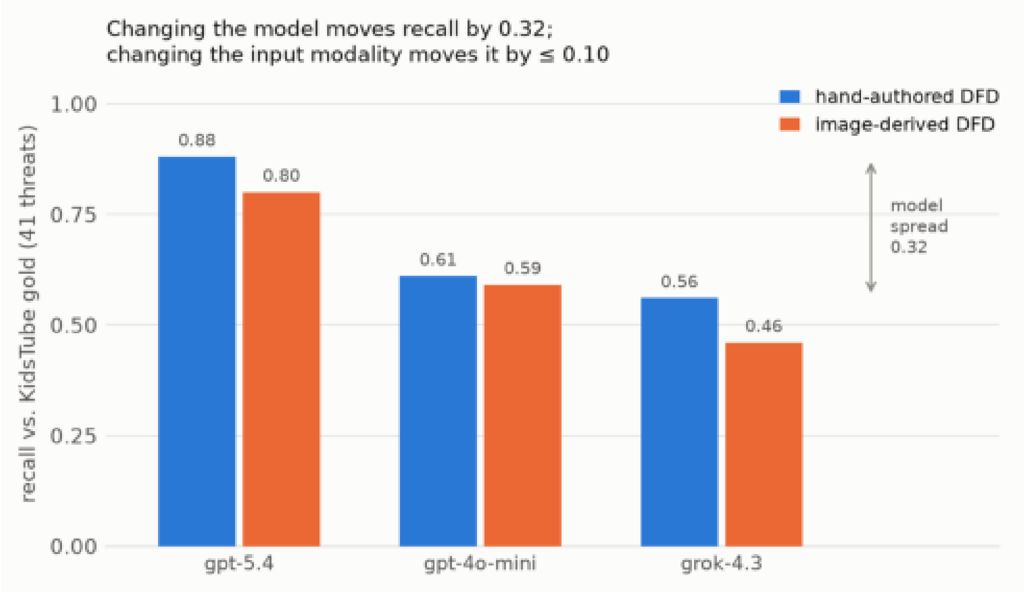
- **Citation validity 1.00, sd 0.00 — over 3,646 grounded threats, three model families, 5 of 5 scenarios**
- It is the mechanism, not the knowledge base: RAG reads the same corpus and still forfeits 0.046
- grounded − ungrounded +0.260 · grounded − rag +0.046 — both 5/5
- F1 separates nothing (−0.003, $p = 0.856$): recall gains are cancelled by the precision cost of higher volume

Consistency across models (RQ1)

KidsTube · grounded · same DFD, three deployments

Input	gpt-5.4	4o-mini	grok-4.3
Analyst DFD (recall)	0.88	0.61	0.56
DFD image (recall)	0.80	0.59	0.46
Citation validity	**1.00**	**1.00**	**1.00**

- **Model choice moves recall 0.32; input modality moves it ≤ 0.10**
- Reading the DFD from an image costs almost nothing measurable
- Threat volume is a fixed habit, not a response to the input: gpt-5.4 gives 195 and 166 threats, grok-4.3 gives 68 and 53
- Citation validity is 1.00 in all eight completed conditions



Source code (RQ2)

KidsTube · gpt-5.4 · grounded · single runs

As a structural input — costly

- Replacing the DFD with a code-derived one drops recall 0.67 → 0.56; citation validity stays 1.00
- Not a citation failure: code models the system at the developer's granularity, so some gold threats have no counterpart flow

As a semantic layer over a trusted DFD — helpful

Condition	flows enriched	flow description	R	citation
Analyst DFD (baseline)	—	38 chars	0.80	1.00
+ source code enrichment	**14 / 17**	**38 → 215 chars**	**0.85**	**1.00**

- Recall +0.05 — two more gold threats — with precision, F1 and citation validity unchanged (n = 1: promising, not established)
- **The adapters fail in opposite directions: an image keeps structure and loses semantics; code keeps semantics and loses structure**

Comparison with PILLAR (RQ3)

Same DFD, same model (gpt-4o-mini) — model and modality both controlled

	PILLAR	Ours
Findings	105	77
P / R / F1	0.21 / 0.54 / 0.30	0.35 / 0.66 / 0.46
Node ids resolving	0.82	1.00
Citations verified after generation	**no**	**yes**

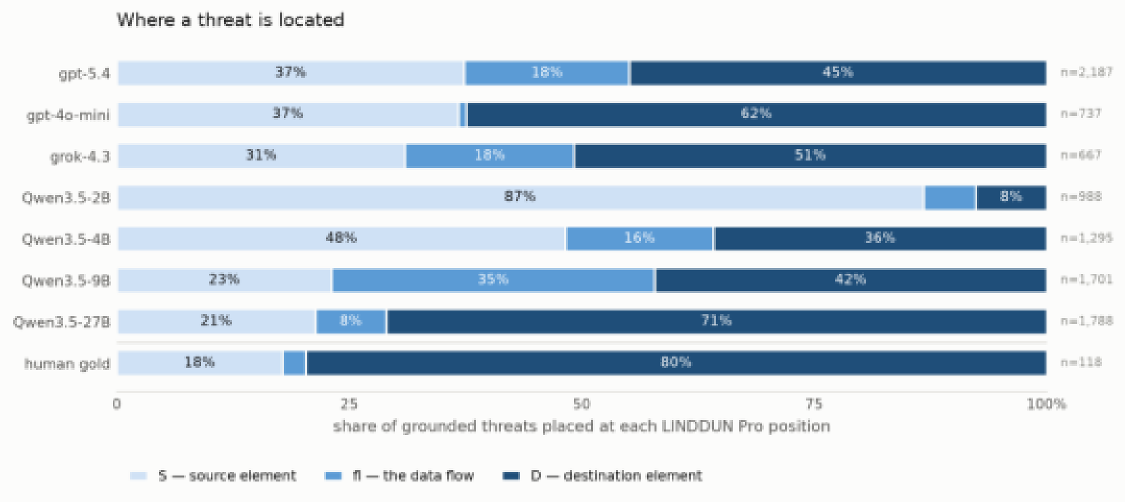
PILLAR's 315 node citations, re-derived against the official trees

- 68% match exactly · 14% resolve only after case-folding (DD.1.1 against Dd.1.1) · 18% are not identifiers at all
- Most failures are therefore not hallucinations — they are identifiers shipped without ever being checked
- **The claim is architectural, not a performance ranking: ours are drawn from a closed vocabulary and re-derived after generation**

What we found by accident

LINDDUN Pro elicits at three positions. Our schema had two.

- **Source, data flow, destination — the middle one could not be expressed**
- Frontier models coerced flow-threats onto an endpoint and still scored 1.00:10–25% of location citations were wrong while reading as perfect
- Found because a 9B model refused to coerce — it answered "fl" and was marked wrong 131 times for being right
- The gold standard had been using the flow position all along, e.g."Child search queries and actions observable on the network"
- **A verifier can only check the answers its schema can express**

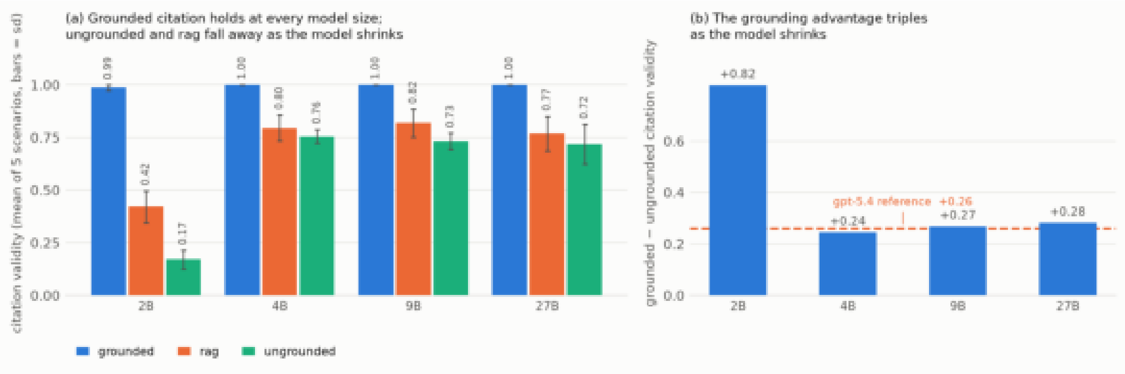


Does grounding still work when the model is small?

Qwen3.5 at 2B / 4B / 9B / 27B · served locally · 180 runs

Model	grounded	rag	ungrounded
2B	**0.99**	**0.42**	**0.17**
4B	1.00	0.80	0.76
9B	1.00	0.82	0.73
27B	1.00	0.77	0.72

citation validity



- **Grounded citation is 1.00 at 4B, 9B and 27B**
- The 2B's 0.987 is the finding: 16 fabricated nodes with the exhaustive menu in the prompt — verification is necessary, not redundant
- The margin explodes as models shrink: +0.817 at 2B, where five of every six ungrounded identifiers do not exist
- RAG is actively harmful below ~4B (0.42 against 0.99 grounded)
- **A small local model can cite correctly — and DFDs are confidential**